

حكومة دبي
GOVERNMENT OF DUBAI



مركز دبي للأمن الإلكتروني
DUBAI ELECTRONIC SECURITY CENTER



ARTIFICIAL INTELLIGENCE (AI) SECURITY POLICY

Version 1



TABLE OF CONTENTS

- 1. INTRODUCTION 4
 - 1.1 Purpose 4
 - 1.2 Scope and Applicability 5
 - 1.3 Data Location 7
- 2. THE AI SYSTEMS LIFECYCLE OVERVIEW 8
- 3. REQUIREMENTS FOR AI PROVIDERS 10
 - 3.1 General Security Requirements 10
 - 3.2 Management of Threats and Vulnerabilities 12
 - 3.3 Design Phase Security Requirements 15
 - 3.4 Develop Phase Security Requirements 16
 - 3.5 Deploy Phase Security Requirements 16
 - 3.6 Monitor Phase Security Requirements 17
 - 3.7 Dispose Phase Security Requirements 18
- 4. REQUIREMENTS FOR AI CONSUMERS 19
 - 4.1 General Security Requirements 19
 - 4.2 Deploy Phase Security Requirements 24
 - 4.3 Monitor Phase Security Requirements 27
 - 4.4 Dispose Phase Security Requirements 28
- 5. REQUIREMENTS FOR AI END-USERS 29
 - 5.1 General Security Requirements 29
 - 5.2 Access Management 29
 - 5.3 Publicly Accessible AI Systems 29
- 6. APPENDICES 31
 - Appendix A: Definitions 31
 - Appendix B: Acronyms 34
 - Appendix C: Threat Descriptions 35
 - Appendix D: Vulnerabilities and Threat Mapping 37

INTRODUCTION



The digital landscape is racing forward, with AI integration transforming industries. While AI unlocks incredible progress, it also introduces new security vulnerabilities¹. This can expose organizations to data leaks, manipulated models, and malicious exploitation that threatens the AI system's confidentiality, integrity, and availability.

Dubai Electronic Security Center (DESC) has developed the AI Security Policy to responsibly navigate this dynamic yet risky landscape. This policy provides the necessary guidance to define clear roles for each stakeholder involved in the AI lifecycle. It also delves into AI systems' unique vulnerabilities and provides recommendations on mitigation strategies. Finally, this policy outlines best practices for secure design, development, deployment, monitoring, and disposal, ensuring AI systems remain robust against evolving cyber threats.

DESC developed this policy to empower its stakeholders to safeguard their digital assets, foster a culture of innovation built on public trust, and unlock the true potential of AI together and securely.

1.1 Purpose

This document aims to foster knowledge about AI's benefits and risks, serving as a policy for AI Providers and AI Consumers in addressing threats in the modern cyber landscape.

The purpose of the AI Security Policy is to enable stakeholders to maximize AI benefits and maintain the flexibility to pursue efficiency-enhancing innovations without compromising the security of the AI Consumers' data. It also includes the awareness of the ethical use of AI through the AI Consumer's established AI Use Policy.

1. Artificial Intelligence and Cybersecurity Research, ENISA, June 2023.

Within this policy, the stakeholders are required to consistently:

- Govern and monitor the main AI actors in the various stages of the AI lifecycle;
- Maintain data security in compliance with the Information Security Regulation V3 (ISR) and the applicable Dubai government laws;
- Implement the policy for a secured AI implementation throughout its lifecycle and all procurement stages.

1.2 Scope and Applicability

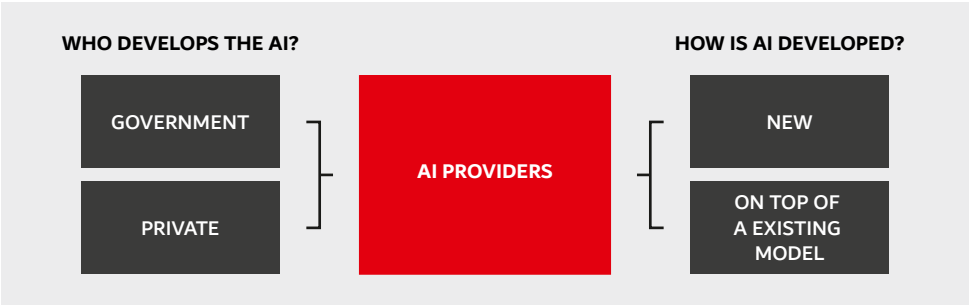
The AI Security Policy provides security best practices for stakeholders involved throughout the entire lifecycle of the AI system. It also emphasizes the importance of continuous of testing, evaluation, verification, and validation to ensure a resilient AI that is monitored throughout its entire lifecycle. This policy is mandatory for all AI Providers offering their services to Dubai government, semi government entities and CII entities. This document applies to both AI Providers and AI Consumers. These stakeholders and the types of AI actors under each stakeholder are described as follows:

AI Providers:

AI Providers are organizations who design, develop, and maintain Artificial Intelligence (AI) systems, either entirely in-house or by collaborating with external parties. External parties can include third-party² AI model development companies to build custom AI or LLM models which can be utilized by other providers.

AI Providers can also be Dubai government, semi-government, and CII entities. These entities may develop AI solutions and models or contract external parties. They may also leverage existing AI models from other providers to create new AI solutions for their internal or external stakeholders or utilize their Internal Development Teams of AI professionals for AI development. Figure 1 explains this scenario.

Figure 1: The AI Providers and how the AI System is develop.



2. ISO/IEC 42001:2023 Artificial Intelligence Management System.

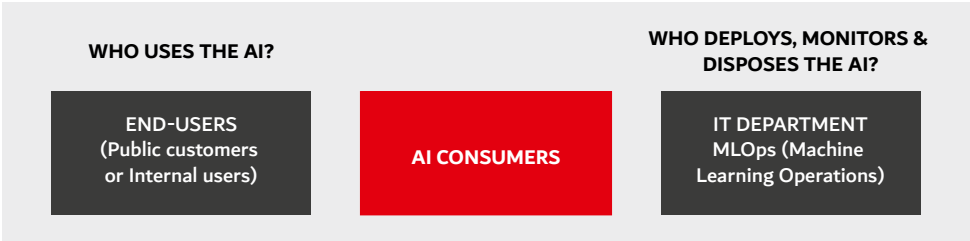
Regardless of the AI Provider structure, several vital roles contribute to creating secure and effective AI solutions. These are referenced from various international publications and best practice documents:

- **AI Designers:** Architect the overall blueprint and structure of AI systems, defining functionality and how the system will achieve its goals;
- **AI Developers:** Translate the AI designer’s blueprint into functional code (systems or AI application source codes), making the AI system operational;
- **LLM Model Providers:** Develop, train, and maintain large language models, enabling the AI system’s language understanding and generation capabilities;
- **Machine Learning Specialists:** Create and optimize the machine learning models that enable the AI system to learn and improve;
- **Data Scientists:** Collect, analyze, and prepare data for use in training machine learning models, which is essential for AI system development.

AI Consumers:

AI consumers are the Government, semi-Government, and critical information infrastructure (CII) entities. These entities utilize AI solutions for internal operations or in public-facing services.

Figure 2: Who uses the AI and how it is secured.



AI Consumers are responsible for the governance and oversight of AI usage within their organization, ensuring that AI is used ethically and responsibly. This involves developing an AI vision and strategy and implementing a governance model to oversee AI practices. The key actors in AI Consumers may include:

- **Senior Management:** Sets the strategic direction and allocate resources for AI adoption and delegates the oversight and implementation and operation of AI systems to the IT Support;
- **Procurement Team:** Guides the procurement process and acquisition of AI technologies and solutions, ensure that purchased AI systems meet the set criteria, and draw the contract in alignment with the legal considerations;

- **Legal Team:** Provides guidance on privacy compliance, ensures that AI systems adhere to regulatory standards such as the Information Security Regulation (ISR) and Dubai Data Privacy Law, and advises on contractual obligations (see 4.1.4 Legal Considerations) related to AI development and deployment;
- **IT Support Staff:** Deploy and maintain the AI infrastructure until its disposal phase;
- **AI Model Development Team:** This team is internal to the AI Consumer. They train the foundational models to safely align with the AI ethical principles;
- **MLOps (Machine Learning Operations) team:** This team often provides technical capabilities to monitor and manage output risks;³
- **End-Users:** Individuals who interact with AI systems as part of their job (entity employees) or as public customers of the AI Consumer.

1.3 Data location

Throughout the AI lifecycle, the data shall remain within the borders of the UAE, irrespective of whether the data is at rest or in motion, backed-up, or used in a disaster recovery event. Only data which is “open data or public data” may be used especially in publicly available AI systems and its upload is at the discretion of the end-user.

3. Gartner, (Gartner, 2024), Generative AI Adoption: Top Security Threats, Risks and Mitigations.

THE AI SYSTEMS LIFECYCLE OVERVIEW



The AI systems lifecycle encompasses various stages; each is critical in creating robust, secure, and trustworthy AI solutions. Understanding this lifecycle is essential for implementing effective AI cyber security strategies, as it highlights the need for careful planning, execution, and ongoing management to mitigate risks and enhance security postures. By executing the AI lifecycle with security in mind, organizations, whether the AI Providers or the AI Consumers, can better benefit from AI technologies while protecting them against evolving cyber threats⁴ and ensuring data confidentiality, integrity, and availability.

Evaluating an AI product against a static set of traditional requirements can quickly become outdated. Therefore, dynamic AI risk management⁵ and assessment are required throughout the AI lifecycle.

Table 1 identifies the lifecycle of an AI system from design to disposal, reflecting the various activities at each phase.

Table 1: AI Systems Lifecycle and related activities

AI Lifecycle Stage	AI lifecycle activities
Design	- Analyze AI system and specification requirements; - Document AI system design and development; - Identify the data collection process; - Execute data pre-processing techniques; - Implement data integration strategies.

4. Identifying Emerging Cyber Security Threats and Challenges for 2030, ENISA.

5. Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST, January 2023.



AI Lifecycle Stage	AI lifecycle activities
Develop	▪ Document AI System technical specifications; ▪ Select and implement the appropriate model architecture; ▪ Fine-tune a foundational model (FM) with the entity's own business-specific data; ▪ Evaluate model performance through rigorous testing; ▪ Validate model robustness through recommended testing and validation methodologies.
Deploy	▪ Setup and maintain the infrastructure ▪ Verify and validate the AI system with the end users ▪ Deploy the AI system in production
Monitor	MLOps (Operations Monitoring): ▪ Operate and monitor AI systems for performance and reliability; ▪ Record event logs to track system behavior. Ensure that a process is in place for AI maintenance, which may include: ▪ Model updates: Regularly update models to improve accuracy and address emerging issues; ▪ Performance tuning: Optimize model performance for efficient output and responsiveness; ▪ Bug fixes: Identify and resolve errors affecting system functionality; ▪ Hallucination monitoring: Detect and mitigate instances where the AI generates incorrect, inaccurate, or illogical outputs. Security Monitoring: ▪ Monitor AI systems for security threats and vulnerabilities; ▪ Record security incidents in event logs; ▪ Ensure security through: ▪ Threat detection; ▪ Vulnerability management; ▪ Incident response.
Dispose	▪ Retire outdated models; ▪ Securely archive data for future use.

REQUIREMENTS FOR AI PROVIDERS



3.1 General Security Requirements

3.1.1 Implementation of Relevant Industry Standards

AI Providers offering their services to Government, semi-Government and CII entities shall implement and comply with the relevant industry standards that ensure and provide the AI Consumers with the confidence to acquire their services and that they maintain the management systems that are internationally accepted. These standards may include, but are not limited to:

- ISO/IEC 27001:2022 Information security, cyber security, and privacy protection – Information security management systems – Requirements the Information Security Management System;
- ISO 22301:2019 Security and resilience – Business continuity management systems – Requirements;
- ISO 31000:2018 Risk Management – Guidelines;
- ISO/IEC 42001:2023 Information technology – Artificial Intelligence – Management system; with Implementation against ISO/IEC 42001:2023 Annex B – Implementation guidance for AI Controls.

3.1.2 Implementation of Dubai Information Security Regulation V3

In addition to the implementation of international standards, AI Providers shall comply with these ISR V3 controls in table below:

Domain	Control	Description
2.7 Information Data Protection	2.7.1	Define a process for identifying critical data exposure in line with specific compliance requirements for protection and privacy, in line with applicable laws and regulations (Eg. Dubai Data Law).
2.7 Information Data Protection	2.7.2	Ensure critical information or data does not get processed, stored and shared outside the boundaries of the UAE, without protection measures and necessary approvals.
4.1 Incident Management Planning	4.1.4	Define and implement incident management process addressing: 1. Assessing information security incidents and categorize based on severity; 2. Appoint qualified/DESC certified incident responders in case of involving external parties for incident handling; 3. Reporting of High severity incidents to DESC for further investigation.
7.3 Disaster Recovery	7.3.5	Implement disaster recovery sites in case their business systems result in a major loss for the whole government, through using an effective approach based on feasibility studies.
11.1 Compliance With Federal And Local Government Legal Requirements	11.1.1	Ensure compliance with the following laws and regulations and related amendments: 1. Federal Law No. 1 of Year 2006 on Electronic Commerce and Transactions; 2. Federal Decree-Law No. 5 of 2012 on Combating Cybercrimes; 3. Transactions and electronic commerce Law No. 2 issued in Year 2002 by Dubai Government; 4. The Executive Council of Dubai Government Resolution Number (13) issued in Year 2012 for Information Security Regulation; 5. The Government of Dubai Human Resources Management Law No. (27) of 2006 and its amendment; 6. Dubai Electronic Security Center Law No.11 of 2014; 7. Law No.26 of 2015 Regulating Data Dissemination and Exchange in the Emirate of Dubai; 8. Law No. (9) of 2022 Regulating the Provision of Digital Services in the Emirate of Dubai; 9. Federal Decree Law No. 34 of 2021 on Combating Rumors and Cyber-crimes; 10. Any other laws pertaining to information security and related to entity's scope of services and align with Government's Strategies and related plans.

Domain	Control	Description
13.2 Cloud Security Principles	13.2.1.1	Prevent handling and storing classified data with a Cloud Service Provider (CSP), outside the legal jurisdiction or geographical boundaries of the United Arab Emirates, including for CSP's Backup or Disaster Recovery purposes.

3.2 Management of Threats and Vulnerabilities

3.2.1 Generic AI Systems' Threats, Vulnerabilities, and Recommended Actions

Generic AI systems are vulnerable to security threats like data poisoning and unauthorized access. These threats can lead to incorrect decisions, data leaks, and potentially system crashes.

By understanding and mitigating common threats, AI providers can improve the security and reliability of their AI deployments. Table 2 lists the common threats and recommended actions. The table has been carefully developed by integrating various references based on international best practices, providing a comprehensive overview of AI-related threats and corresponding responsibilities. Another reference mapping the threats to vulnerabilities is found on Appendix D.

Table 2: Common threats and recommended action.

	Data-related Threats			Model-related Threats			Model-related Threats	Operational Threats			Human-related Threats			System Integrity Threats										
Recommended Actions		Data Poisoning/Label Modification	Data or Model Disclosure	Data Interception	Input of Confidential, IP, and PII Data	Adversarial Attacks	Evasion	Bias	Model Theft or Disclosure	Hallucination (GenAI)	Direct Back-end Attack/Prompt Injection	Compromise of a Component	Failure or Malfunction of AI System	Supply Chain Vulnerabilities	Insecure API Interaction	Insufficient Logging	No validation and Verification	Unauthorized Access/Retrieval	Advanced Social Engineering Attacks	Human Error	Unfair/ Unlawful Processing	Abuse	No Explainability	Use of Vulnerable Code
	Add adversarial examples to the training dataset					●	●																	
	Apply data governance for training data	●	●					●																
	Apply integrity checks and output validation procedures	●														●								
	Communicate applicable legal requirements to users																			●	●			
	Conduct user training and awareness							●		●								●	●	●				

	Data-related Threats			Model-related Threats			Model-related Threats			Operational Threats			Human-related Threats			System Integrity Threats							
Recommended Actions	Data Poisoning/ Label Modification	Data or Model Disclosure	Data Interception	Input of Confidential, IP, and PII Data	Adversarial Attacks	Evasion	Bias	Model Theft or Disclosure	Hallucination (GenAI)	Direct Back-end Attack/Prompt Injection	Compromise of a Component	Failure or Malfunction of AI System	Supply Chain Vulnerabilities	Insecure API Interaction	Insufficient Logging	No validation and Verification	Unauthorized Access/Retrieval	Advanced Social Engineering Attacks	Human Error	Unfair/Unlawful Processing	Abuse	No Explainability	Use of Vulnerable Code
Control of training data sets to ensure that there is no bias in the AI system	●						●																
Develop and implement policies, including the covering the treatment of confidential, PII, and IP information		●		●									●										
Develop reliable and resilient AI model design								●				●	●										
Develop Secure APIs with strong authentication, authorization, and input validation														●		●	●						
Document the AI models used																						●	
Draw contractual arrangements to ensure sufficient security in products purchased											●		●										
Employ strong encryption mechanism		●	●					●															
Ensure data minimization		●		●																			
Ensure the hosting provider supplies domain- or task-specific LLMs suitable for your use cases.									●				●										
Ensure that the latest update of the AI System is running											●	●											
Ensure well tested guardrails are implemented							●			●		●											
Identify legal requirements																				●			
Implement a process to ensure “security by design”										●			●										●
Implement a secure software development lifecycle													●						●				●

	Data-related Threats			Model-related Threats			Model-related Threats		Operational Threats			Human-related Threats			System Integrity Threats								
Recommended Actions	Data Poisoning/Label Modification	Data or Model Disclosure	Data Interception	Input of Confidential, IP, and PII Data	Adversarial Attacks	Evasion	Bias	Model Theft or Disclosure	Hallucination (GenAI)	Direct Back-end Attack/Prompt Injection	Compromise of a Component	Failure or Malfunction of AI System	Supply Chain Vulnerabilities	Insecure API Interaction	Insufficient Logging	No validation and Verification	Unauthorized Access/Retrieval	Advanced Social Engineering Attacks	Human Error	Unfair/Unlawful Processing	Abuse	No Explainability	Use of Vulnerable Code
Implement a strong built-in prompt injection detection and prevention capabilities.										●													
Implement detailed logging and monitoring systems to track and analyze activities															●				●		●		
Implement robust data validation and cleaning processes	●															●							
Implement strong access control measures (Authorization, Multi-factor Authentication)														●			●				●		
Incorporate adversarial training and detection mechanisms					●					●													
Monitor, record, and audit the AI system access and use															●		●		●				
Run ethical phishing attacks etc. for awareness																		●					
Use of secure communication channels			●											●									
Use reliable and verified sources for labelling data	●																					●	
Use secure environments for testing		●																					
Validate and cross check data labels to ensure accuracy	●																						
Vet third party components, conduct security audits, and use secure dependencies											●		●										●
Where necessary, collect user consent																			●	●			

3.3 Design Phase Security Requirements

3.3.1 Security-by-Design

AI providers shall embed security considerations into every aspect of the system's architecture and design to proactively prevent security issues. This approach includes, but is not limited to, defining secure coding standards, secure logging, and incorporating threat modeling. Making security a foundational element ensures that systems are built to be robust, resilient, and resistant to potential threats from the outset. AI providers shall also implement the DESC ISR V. 3 controls on security by design:

"ISR Control 8.1.1.2. Design and implement a 'Security-by-design' approach, ensuring that systems and all their components are created incorporating related DESC-issued policies and controls with a proactive approach integrating security from the very start, providing security and privacy."

AI Providers shall ensure that during the design phase the system meets technical and business requirements. They should start by analyzing the AI system's specifications and requirements, working closely with the AI Consumer who provides the business requirements, goals, and constraints the AI system needs to meet. Next, they document the AI system design and development process, creating detailed architecture and development plans.

3.3.2 Data Security

AI Providers shall incorporate security measures to protect data from unauthorized access, alteration, or destruction. This includes designing encryption protocols for data in transit and at rest, incorporating data anonymization techniques to reduce the risk of breaches, and specifying strict access control mechanisms to ensure that only authorized personnel can access sensitive information. Additionally, planning for secure data storage and defining audit mechanisms are essential to maintaining data integrity and confidentiality.

AI Providers shall identify the appropriate data collection processes, determining the sources and methods for obtaining necessary data while ensuring data security and compliance. The AI Providers shall execute data pre-processing techniques, cleaning, normalizing, and transforming the data to make it suitable for the AI system, focusing on maintaining data integrity and confidentiality. Together with the AI Consumer, they shall implement data integration strategies, combining data from various sources into a cohesive and usable dataset. This aligns the technical aspects with business needs and ensures data security is built from this phase.

3.4 Develop Phase Security Requirements

3.4.1 Secure Development

During the development phase of the AI lifecycle, AI Providers are responsible for transforming the design into a functional AI system. They shall document the AI system's technical specifications, clearly outlining all technical details. They shall select and implement the appropriate model architecture, choosing the best algorithms and frameworks to meet the system's requirements. Also, during the development phase, the AI providers train the model on the prepared data, optimizing it to learn patterns and make accurate predictions.

3.4.2 Secure Testing and Validation for General AI Systems

Testing and validating General AI systems presents a unique challenge due to their broad capabilities and potential for unforeseen behaviors. AI systems shall undergo complete testing, evaluation, validation, and verification.

AI Providers shall evaluate model performance through rigorous testing, employing various industry-recommended testing and validation methodologies to ensure the model's reliability and stability under different conditions. This process includes threat-aligned testing, where the model is assessed against potential real-world threats such as those outlined in section 3.2. Red teaming involves simulating attacks to identify vulnerabilities and security control validations, where specific security is tested for effectiveness. Controls for security validation include access controls, data encryption, and anomaly detection systems.

3.5 Deploy Phase Security Requirements

3.5.1 ICT Infrastructure Setup

AI Providers shall choose secure and reliable ICT infrastructure for their AI systems, including training, deployment, and operation.

The underlying ICT infrastructure shall enable comprehensive logging, data origin tracking, auditability, and robust security measures for sensitive data protection, access controls, and continuous monitoring of the AI system's behavior.

Other considerations include:

- **Scalability and Performance:** Ensure the ICT infrastructure can handle the computational demands of the AI system, especially resource-intensive applications, and LLM that require large GPU (Graphics Processing Unit) infrastructure for runtime inference needs..
- **Interoperability:** Design the infrastructure to facilitate seamless communication and data exchange, enabling collaborative and integrated AI solutions.

- **Sustainability:** Consider energy efficiency and responsible resource consumption throughout the selection and management of ICT infrastructure.

3.5.2 Verify, Validate, and Deploy

AI Providers shall verify and validate the AI system with end-users, conduct user acceptance testing, and incorporate feedback to fine-tune the system. The AI Consumer participates in the validation process, providing critical input and making key decisions on system adjustments.

Concluding the Development phase, the AI Providers finally deploy the AI system in production, ensuring a smooth transition and ongoing monitoring to address any issues.

3.6 Monitor Phase Security Requirements

3.6.1 Continuous Monitoring

AI Providers shall continuously monitor their deployed systems to ensure ongoing and optimal performance, trustworthiness, and security. This involves tracking key metrics such as performance (i.e., time to generate response), trustworthiness (i.e., metrics to detect hallucinations), and security metrics (e.g., resistance to phishing and social engineering resistance). Setting alert thresholds for monitoring, investigating issues, and taking corrective actions is also necessary. This monitoring should include recording AI system event logs to track system activities, detect anomalies, and support troubleshooting.

AI Providers shall ensure a comprehensive maintenance process, which includes model updates, performance tuning, and bug fixes to keep the system up-to-date and functioning efficiently.

3.6.2 Response and Recovery

AI Providers shall establish a thorough response and recovery process to address emerging threats against AI systems, especially given the rapid development of new attack methods targeting LLMs. This process is essential for ensuring the ability to identify, assess, and quickly respond to new vulnerabilities, such as prompt injections, adversarial attacks, and other nascent threats. This process should include continuous threat monitoring, rapid investigation, and the deployment of security patches or model updates as needed. Additionally, regular model performance tuning and bug fixes must be conducted to maintain system integrity and efficiency while minimizing risks.

3.6.3 Vulnerability Management

AI Providers shall continuously monitor the system for existing and emerging vulnerabilities. Threats outlined in section 3.2 shall be actively tracked to prevent them from ex-

exploiting known weaknesses and compromising AI systems' confidentiality, integrity, and availability. Effective vulnerability management requires a comprehensive strategy. This includes establishing clear policies and procedures for reporting and addressing vulnerabilities and well-defined communication protocols to keep all stakeholders informed.

3.7 Dispose Phase Security Requirements

3.7.1 Model Retirement

AI Providers shall implement a secure model retirement process to ensure responsible data management. This process shall address outdated models to prevent potential security risks and unauthorized access. Model retirement shall cover:

- **Secure Decommissioning:** Outdated models shall be securely decommissioned. This may involve deleting them entirely or taking steps to render them unusable;
- **Data Anonymization:** Any data associated with retired models shall be anonymized.

Following these steps ensures proper handling of outdated models and safeguards any associated data.

3.7.2 Data Archiving

AI Providers shall implement secure data archival practices to ensure responsible data management. This involves archiving data according to industry practices, specifically compliance with ISR V3 Controls. Data archiving practices shall adhere to relevant ISR Controls, including:

- **Control 5.5.3:** establishes a clear policy for data retention periods during archiving;
- **Control 7.4.2.7:** This control encrypts backups and archives whenever it's technically feasible and appropriate.

Following these controls ensures that data is retained for the necessary period with proper access controls and encryption. This safeguards sensitive information during long-term storage.

REQUIREMENTS FOR AI CONSUMERS

4

4.1 General Security Requirements

Secure AI deployments rely on a foundation of solid general security practices. These include aligning business goals with AI strategy, establishing robust strong governance with clear accountability, and ensuring compliance with relevant regulations. Careful vendor selection, focusing on security practices, minimizes potential risks external providers introduce.

4.1.1 Business Strategy

AI Consumers play an essential role in the general adoption of AI and responsible use, utilizing its benefits while maintaining security and safety. AI Consumers shall document the rationale and goals behind acquiring or developing an AI system, laying the groundwork for maximizing benefits while minimizing risks.

The AI Consumer shall consider and document these key factors:

- **Business Need:** Clearly define the driving force behind acquiring or developing the AI system. Is it a strategic business case, a customer request, or a response to government policy? Aligning the AI solution with a specific need ensures it delivers targeted value;
- **Data Requirements and Training:** Understanding how the model will be trained and the data needed for that training is crucial. This helps assess data availability, potential biases, and potential privacy concerns before development begins.
- **Data Location:** Throughout the AI lifecycle, the data shall remain within the borders of the UAE, irrespective of whether the data is at rest or in motion, backed-up, or used in a disaster recovery event.



4.1.2 Governance, Risk and Compliance

AI Consumers shall implement secure and responsible AI systems through establishing strong AI governance policies and clear lines of accountability throughout the AI lifecycle.

AI governance is a comprehensive framework encompassing various aspects, including risk assessment, regulatory compliance, contractual agreements, and ethical considerations.

AI Risk Assessment

The AI Consumers shall define and establish an AI risk assessment process aligned with their AI Policy. They shall also identify and document objectives to guide the responsible use of AI systems. AI Consumers operating in different contexts can have different objectives for what constitutes the responsible development and procurement of AI systems.

AI Consumers shall appropriately classify AI systems intended for use as safety components for AI Consumers in critical sectors, such as those managing and operating road traffic, transportation, utilities, and other high-risk systems. Their failure or malfunctioning may lead to significant disruptions of daily social and economic activities and potentially risk health and safety on a large scale.

The risks associated with the AI across its lifecycle can be determined by the AI Consumer through an examination of the risk assessment questions in Table 3.

Table 3: Guiding questions for risk assessment

Stages	AI Risk Assessment Considerations
Design	▪ Is the use of AI necessary for the desired outcome? ▪ Do we have consent to use the data sources required by the solution? ▪ Do we fully understand the implications of using external data, models, or solutions?
Develop	▪ Do we have the right skills or domain expertise to develop the solution? ▪ Does the development process protect data confidentiality, integrity, and availability? ▪ Does the acceptance criteria set appropriate levels of accuracy to ensure the model performance is satisfactory?
Deploy	▪ Have users received adequate training to ensure they understand the system’s output? ▪ Is it transparent to users how the solution is deriving an output? ▪ Is the IT Team provided with the right training to monitor the AI Infrastructure?
Monitor	▪ Do the AI administrators know what metrics to examine to validate that models are operating as expected? ▪ Is there a straightforward process for updating or refining models using new data?

Stages	AI Risk Assessment Considerations
Disposal	▪ How will data associated with the AI system be handled during disposal? ▪ Can the following options apply? Consider options like: ▪ Secure erasure of all training data, user data, and system outputs; ▪ Anonymization of data for potential future research purposes, ensuring compliance with data privacy regulation.

By aligning risk assessment with the objective and goals of AI development, AI Consumers can prioritize security measures and identify potential risks across various areas of impact, such as accountability, fairness, transparency, explainability, safety, security, and privacy.

4.1.3 Vendor Selection and Management

Many of AI’s legal implications are undefined and potentially very costly. A joint effort from IT, MLOps, and legal is critical to identifying gaps and addressing obscure decisions. Table 3 lists some key considerations at every stage when procuring the services of an AI Provider.

Procurement Stage	Key Activities	Recommended Actions
Preliminary Activities (During Tendering)	▪ Define business needs and requirements; ▪ Develop tender documents; ▪ Evaluate vendor proposals; ▪ Shortlist vendors.	▪ Include security requirements in tender documents (data encryption, access controls, secure-by-design coding practices); ▪ Request information on vendor’s security methodologies for designing and developing AI systems; ▪ Evaluate vendor’s experience in threat modeling for AI projects; ▪ Vendor Certifications: Seek vendors with recognized security certifications (e.g., ISO 27001) demonstrating a commitment to secure development practices; ▪ CSP Compliance: AI Providers with their services or AI systems on the cloud shall acquire the DESC CSP Security Certificate; ▪ Incident Response Plans: Seek vendors with well-defined incident response plans outlining how they handle security breaches and data leaks; ▪ Transparency in Security Practices: Seek vendors who are transparent about their security practices and provide detailed information upon request; ▪ Disaster Recovery Plans: Ensure the vendor has a robust disaster recovery plan to mitigate the impact of potential outages or security incidents impacting the AI system.
Initiating and coincident activities	▪ Onboard vendor; ▪ Monitor development progress; ▪ Review code security; ▪ Address security issues.	▪ Ensure that all contractual requirements, including privacy and security provisions, are explicitly recorded in the service level agreement; ▪ Ensure the agreed secured development approach, testing, evaluation, and validation methodologies are applied; ▪ Monitor that all agreed operational activities in the Deploy and monitor lifecycle stages are adhered to.

Procurement Stage	Key Activities	Recommended Actions
Concluding activities	▪ Review contract performance; ▪ Evaluate potential new vendors (if not renewing); ▪ Develop a data deletion plan; ▪ Secure data transfer (if not renewing).	▪ Assess the vendor’s process for secure retirement and disposal of obsolete AI models; ▪ Ensure the associated data archiving at the end of the contract follows the defined process; ▪ Ensure a secure data transfer process if not renewing the contract, with proper encryption and access controls; ▪ Ensure contract terms guarantee data deletion upon disposal, adhering to relevant data privacy regulations.

4.1.4 Legal Considerations⁶

The AI Consumer shall review key considerations with their Legal department when procuring an AI system or services from AI Providers. The following are some of these critical considerations. The specific legal clauses shall be drafted by the AI Consumers’ Legal Department:

Product Warranties:

- AI Providers shall clearly define and assign responsibility for product warranties in the development process, considering the involvement of AI components.

Terms and Conditions:

- AI Consumers shall review and update existing terms and conditions to address specific considerations for AI products, including user prompts, output ownership, data privacy, compliance, liability, and limitations on output use.

End-User License Agreements (EULAs):

- AI Consumers shall modify EULAs to prevent liability for plagiarism, bias propagation, or intellectual property infringement arising from AI-generated content;
- AI Providers shall carefully design EULAs for AI platforms, addressing user prompts, output rights, data privacy, compliance, liability, and limitations on output use.

Intellectual Property:

- AI Consumers shall evaluate and analyze the risks to intellectual property ownership when utilizing AI tools for code generation. Formulate clear guidelines and safeguards to mitigate these risks.

6. Unlocking Public Sector AI – AI Procurement In a Box: Workbook, Toolkit, World Economic Forum, June 2020.

Insurance Coverage:

- AI Consumers shall evaluate the sufficiency of current insurance policies for AI-related risks. Explore the need for additional coverage if required.

Copyright:

- AI Consumers shall acknowledge that copyright protection necessitates human authorship;
- AI Consumers shall identify and mitigate potential plagiarism-related liabilities, bias propagation, or intellectual property infringement due to AI misuse.

Contractor Agreements:

- AI Consumers shall guarantee that explicit agreements are established with contractors concerning the proper use of AI in development or service provision.

Data Commissioning:

- AI Consumers shall specify the protocols for the secure return or deletion of all data at the AI system's end-of-life. Ensure the AI Provider is obligated to return the data to the AI Consumer or securely delete it.
- AI Consumers shall require the AI Provider to provide a certification of data deletion or records of data return to confirm that all data has been handled according to the agreed protocols.

AI-Hosting on Third-Party Cloud

- AI Providers shall ensure its compliance with the Cloud Security Provider (CSP) Security Policy requirements.

4.2 Deploy Phase Security Requirements

4.2.1 ICT Infrastructure Setup

While Section 3.5.1 outlines ICT infrastructure setup requirements for AI Providers, similar security considerations extend to AI Consumers. When deploying AI on-premises, AI Consumers shall align the infrastructure's security with industry best practices, such as ISR V3 and relevant cyber security standards. AI Consumers shall perform regular security audits of the AI's ICT infrastructure, mirroring the security posture already in place to maintain the existing systems.

4.2.2 AI System Evaluation and Verification

Following deployment, AI Consumers shall continuously evaluate and verify the performance of their AI systems. This ongoing process ensures that the system remains effective and reliable. Together with the AI Provider, the AI Consumer shall conduct the following:

- **Regular Validation:** Establish a routine for testing and monitoring AI outputs. This helps identify potential issues and ensure the system consistently delivers accurate results;
- **Robustness Assessment:** Evaluate the model's ability to handle unexpected inputs and resist adversarial attacks. This strengthens the system's resilience against manipulation;
- **Broader Implications:** Consider fairness, bias, and explainability in the AI system's performance;
- **Ongoing Reviews:** Implement regular performance monitoring to maintain system integrity and effectiveness;
- **Prompt Issue Resolution:** Address any problems quickly to ensure optimal operation;
- **Performance Metrics:** Set specific metrics related to performance, trustworthiness, and security to measure the system's success.

Consider the broader implications of the AI system, such as fairness, bias, and explainability. Implement ongoing performance reviews and monitoring to maintain the system's integrity and effectiveness. Address any issues promptly to ensure optimal operation. Set specific metrics related to performance, trustworthiness, and security.

4.2.3 Training, Communication, and Awareness

AI Consumers shall ensure that employees throughout organizations receive training to understand artificial intelligence in general and the future potential consequences of building, buying, or utilizing AI systems.

To use the AI systems effectively, users may require specific training. For GenAI, for example, employees must be trained on topics such as effective prompt engineering and validation of system output as hallucination.

Training for permissible use and security awareness shall target all employees and be more specialized for certain positions such as human resources, legal, developers, data teams, and security teams.

4.2.4 AI Use Policy

AI Consumers shall develop and implement robust AI Use Policy for responsible AI development and deployment, encompassing all types of AI. The policy should align with AI principles and ethics. Key considerations include, but are not limited to, the following:

Accountability:

- Understand and adhere to the defined role and responsibilities in AI development and use;
- Escalate concerns about potential risks or ethical implications promptly.

Confidentiality:

- Implement access controls and data minimization techniques to maintain the confidentiality of sensitive information exposed to AI models during training.

Data Handling:

- Follow stringent data collection protocols, implement robust data security measures, and adhere to data retention/deletion procedures.

Data Privacy:

- Ensure data privacy by anonymizing training data or obtaining explicit user consent for data used in AI content generation.

Fairness:

- Actively identify and address potential biases in training datasets to promote fairness.

Training and Reporting:

- Engage in AI training programs to enhance the end-user's skills and understanding;
- Report any violations of the AI Use Policy to ensure compliance and continuous improvement.

Transparency:

- Document project rationales clearly and consider using explainable AI techniques to enhance transparency.

4.3 Monitor Phase Security Requirements

4.3.1 AI Maintenance

AI Consumers shall provide feedback on system performance and raise any issues encountered during the AI operation. They shall monitor the frequency and scope of model updates, performance tuning, and necessary bug fixes to align the AI system's operation with their defined business objectives and requirements. If they see indications of the AI system presenting a risk or diverting from the intended interaction, especially with the end-users, they shall inform the AI Provider.

4.3.2 Incident Reporting

AI Consumers shall develop a well-defined incident reporting process. This process ensures timely identification, investigation, and remediation of security incidents affecting AI systems.

The following key areas may be considered:

- **Clear Reporting Procedures:** The AI Use Policy shall establish clear procedures for reporting suspected security incidents. This includes defining what constitutes an incident, who to report to (designated security personnel), and the information required for effective investigation (e.g., system logs, error messages);
- **Prompt Reporting:** Employees are encouraged to report suspected incidents promptly, even if the exact nature or impact is unclear. Early detection allows for a faster response and minimizes potential damage;
- **Investigation and Analysis:** Upon receiving an incident report, a dedicated team shall investigate the cause, identify exploited vulnerabilities, and assess the potential impact;
- **Remediation and Corrective Actions:** Based on the investigation findings, a plan for remediation and corrective actions shall be implemented. This might involve patching vulnerabilities, updating models, or retraining AI systems with more robust datasets;
- **Learning and Improvement:** The incident response process shall include a feedback loop for continuous improvement. Lessons learned from past incidents can strengthen security protocols and enhance the overall resilience of AI systems.

4.4 Dispose Phase Security Requirements

4.4.1 Model Retirement

The AI Consumer shall securely decommission and dispose of outdated models received from AI providers. This includes deleting or anonymizing any associated data to prevent unauthorized access and potential misuse of sensitive information following ISR V3 Control 2.5.1

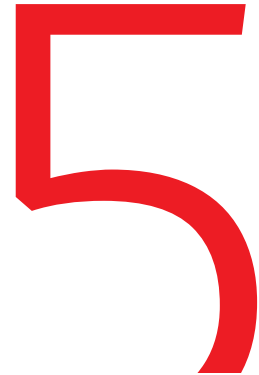
4.4.2 Secure Data Archiving with ISR Compliance

AI Consumers shall ensure the effective implementation of the specific ISR controls that relate to secure data archiving:

- **Retention Periods:** Establish a clear policy on data retention periods based on regulatory requirements and the organization's needs following ISR Control 5.5.3;
- **Access Controls:** Implement strong access controls to restrict access to archived data only to authorized personnel;
- **Encryption:** Encrypt backups and archives whenever technically feasible and appropriate, following ISR Control 7.4.2.7.

AI Consumers shall regularly review and update data archival protocols to ensure they remain aligned with the ISR.

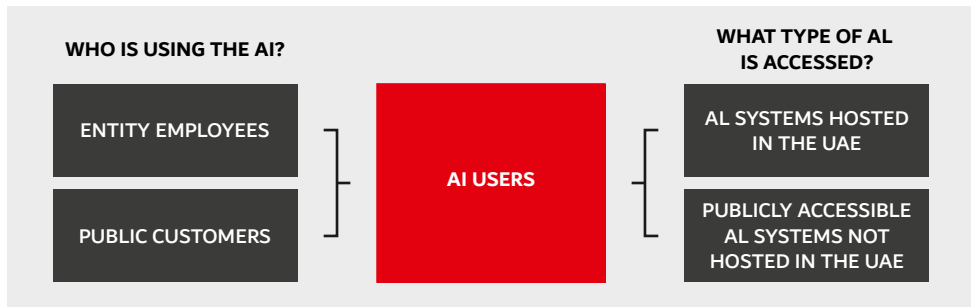
GUIDELINES TO AI END-USERS



5.1 General Security Requirements

Entity employees and public customers who are the AI end-users should adhere to strong security practices to ensure safe interactions with AI systems. This includes understanding the AI system's functionality and limitations, practicing caution against potential security threats (e.g. phishing or social engineering), and following established guidelines for secure data handling. The entity employees must also report any suspicious behavior to the IT or security teams promptly to prevent exploitation. End-Users should attend the continuous education and awareness trainings (section 4.3.3) which are essential for maintaining a secure environment in AI interactions.

Figure 3: AI users and the AI systems utilized.



5.2 Access Management

Entity employees and public customers must adhere to stringent access management practices to ensure the security of their interactions with AI systems. This includes using strong, unique passwords that combine letters, numbers, and special characters, and enabling multi-factor authentication (MFA) wherever possible. Customers should regularly update their passwords and avoid using the same password across multiple platforms. It is also crucial to remain vigilant against phishing attempts and to report any suspicious ac-

tivity immediately. Security of personal devices must be ensured, such as keeping software up to date and using reliable antivirus programs, further enhances protection.

5.3 Publicly Accessible AI Systems

When using publicly available AI tools, such as GPT models, image generators, or video generators, AI End-Users must be aware of the security and privacy implications. The following may be implemented as precautionary security measures:

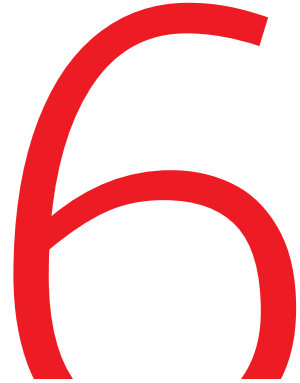
- Avoid sharing personal, confidential, or proprietary information through these platforms;
- Public AI tools are typically hosted on external servers, making data potentially accessible to third parties or vulnerable to unauthorized access;
- Be cautious of AI-generated contents' accuracy, as these models can produce misleading or biased outputs;
- Only data classified as "open data" may be used especially in publicly available AI systems, and its upload is at the discretion of the end-user;

For license-based applications which integrates AI into software, users:

- Must review the licensing terms and ensure that it aligns with the internal policy;
- Are responsible for verifying the safety and legality of the AI's output, particularly in sensitive or regulated environments;
- Must ensure that information assets are handled according to ISR Domain 2: Information and Information Assets Management.

Adopting robust security practices when using AI tools, whether publicly available or licensed, is crucial for safeguarding data and ensuring compliance with relevant standards. By remaining vigilant, following best practices, and understanding the implications of AI-generated content, the full potential of AI can be harnessed responsibly and securely.

APPENDICES



Appendix A: Definitions

Terms	Definition
Access Control	Access control is a mechanism to enable authorized people to access entity resources (physical and logical) while preventing unauthorized people from doing the same.
Accountability	Accountability means that people is responsible for their action. This can be achieved through audit trails and non-repudiation.
Acquisition	Acquisition is a process defined by a series of phases that may include conceptualization, initiation, design, evaluation, development, testing, production, modification and disposal of services and systems.
AI Ethics	An emphasis on ethical principles such as human agency and oversight, technical robustness and safety, privacy and data governance, transparency, diversity, non-discrimination and fairness, societal and environmental well-being, and accountability (Adopted from EU AI Act).
AI Principles	It emphasizes AI principles: human agency and oversight, technical robustness and safety, privacy and data governance, transparency, diversity, non-discrimination and fairness, societal and environmental well-being, and accountability. (Adopted from EU AI Act).
Audit Log	A security-relevant sequential record, set of records, or destination and source of records that provide documentary evidence of the sequence of activities that have affected at any time a specific operation, procedure, or event.
Authentication	Authentication is the act of verifying a claim of identity. It is usually one or more of the following: something you know (password), something you have (identification card) or something you are (fingerprint).

Terms	Definition
Authorization	Authorization determines what a subject can do on the system. Authorization happens right after identification and authentication.
Availability	Part of the Information Security Triad; availability means that information should be available when it is needed.
Awareness	Awareness is the knowledge and attitude members of an entity possess regarding the protection of the physical and, especially, information assets of that entity. Many entities require formal security awareness training (including handling threats related to social engineering) for all workers when they join the entity and periodically thereafter, usually annually.
Breach	A security or data breach, is an external act that bypasses or contravenes security policies, practices or procedures.
Compliance	Compliance is the act of adhering to, and demonstrating adherence to, a standard or regulation (international or internal).
Confidentiality	Part of the Information Security Triad; confidentiality means the nondisclosure of certain information assets except to an authorized person as per the classification level of that asset.
Data Leak	Leakage is allowing sensitive or confidential information to become known by someone not authorized to view such information.
Dubai Government Entities	Any organization legally established by Dubai Government with well-defined roles and responsibilities, including but not limited to, authorities, departments, councils, committees, etc.
Governance	Information Security governance is a subset of enterprise governance that provides strategic direction, ensures objectives are achieved, manages risk appropriately, uses entity resources responsibly, and monitors the success or failure of the enterprise security program/management system.
Incident	An incident can be thought of as violation or imminent threat of violation of computer security policies, acceptable use policies, or standard security practices.
Information Security	The act of protecting information that may exist in any form, whether spoken, written, processed or transmitted electronically, etc. from unauthorized access, use, disclosure, disruption, modification or destruction, with the objective of ensuring business continuity, minimizing business risk, and maximizing return on investments and business opportunities.

Terms	Definition
Integrity	Part of the Information Security Triad; integrity means that data cannot be modified without authorization, intentionally or unintentionally.
Malicious Attack	Malicious attack is an attempt to infiltrate a computer system without the owner’s informed consent to make it unavailable, steal information or use it to attack other computers using a malicious software or code. (This includes computer viruses, worms, Trojan horses, spyware, dishonest adware, crime ware, rootkits, and other malicious and unwanted software).
Policy	An information security related document written and maintained to provide governing statements regarding any information security key process, through setting the rules for expected behavior by users, systems administrators, management, and security personnel; authorize security personnel to monitor, probe, and investigate; define and authorize the consequences of violation; define the entity consensus baseline stance on security; help minimize risk; and help track compliance with regulations and legislation.
Privacy	Privacy is the ability of an individual or group to stop information about themselves from becoming known to people other than those they choose to give the information to.
Risk	Risk is the quantifiable likelihood of potential harm that may arise from a future event.
Risk Assessment	Risk assessment is a step in the risk management process to determine the qualitative and quantitative value of risk in relation to a recognized threat. Quantitative risk assessment requires calculations of two components of risk; R, the magnitude of the potential loss L, and the probability P; that the loss will occur.
Risk Management	The process of analyzing risk and exposure through identification, assessment and prioritization followed by monitoring and applying controls to best handle the exposure.
Security Controls	Security controls are safeguards or countermeasures to avoid, counteract or minimize security risks. They could be preventive, detective or corrective.
Security of ICT Infrastructure	Describes the structure, components and topology (connections and layout) of security controls within an enterprise’s IT infrastructure. The security architecture or the Framework shows how defense in depth is implemented and how layers of control ⁷ are linked in implementing security controls in the entity’s IT environment.

7. A multilayer framework for good cyber security practices for AI, ENISA, June 2023.

Terms	Definition
Senior Management	A layer of management in an entity whose primary job responsibility is to monitor activities of subordinates as well as the day-to-day operations; for example, Managers/ Directors of HR, IT, Finance, Marketing, Engineering, while reporting to upper management such as CEO or Director General.
Stakeholders	A person, group or organization that has interest or concern in an organization. Stakeholders can affect or be affected by the organization's actions, objectives and policies.
Systems/AI Applications Source Codes	Any collection of computer instructions written using computer language.
System Acquisition/ Development Lifecycle	A process of buying or creating or altering information systems, and the models and methodologies that people use to develop these systems.
Threats	Threat is the expressed potential for the occurrence of a harmful event such as an attack. It could be any party with the intent and capability to exploit vulnerability in an asset such as a malicious hacker or a disgruntled employee.
Vulnerability	Vulnerability is weakness in an asset that can be exploited

Appendix B: Acronyms

Terms	Definition
AI	Artificial Intelligence
CII	Critical Information Infrastructure
ICT	Information and Communication Technology
ISO	International Organization for Standardization
ISR	Information Security Regulation
LLM	Large Language Models
ML	Machine Learning

Terms	Definition
MLOps	Machine Learning Operations
SBD	Secure by Design

Appendix C: Threat Descriptions

Threat Name	Threat Description
Abuse	Intended misuse of the AI system, be it in business processes to alter results or by using the AI system for security attacks.
Advanced Social Engineering Attacks	LLMs can help create high-quality phishing and other social engineering attacks in very little time, even by non-educated attackers.
Compromise of a Component ⁸	AI components can be compromised, e.g., by exploiting vulnerabilities in open-source libraries used by the algorithm, such as PyTorch or TensorFlow.
Data Interception	If malicious actors intercept the data exchanged between AI systems and external sources, sensitive information could be exposed, leading to data breaches, identity theft, or unauthorized access to personal or corporate data.
Direct Back-end Attack	Such attacks can work by directly attacking the AI system's back end and gaining access to the management layer and data sets.
Evasion	The attacker finds small perturbations that can be used to exploit the algorithm's output (also known as adversarial attacks).
Failures	This is related to the failure or malfunction of an AI application; it can be caused by several reasons, such as a denial-of-service attack, due to wrong input, or an untreated handling error.
Human Error	This can relate to developers making mistakes, users not using the AI system correctly, or data engineers needing to apply more care to their data.
Input of Confidential, IP, and PII Data	If employees mistakenly input confidential, IP, and PII data into LLMs, the LLMs can use this as "learning input" and might replicate it elsewhere.
Model or Data Disclosure	Information about the AI model(s) used configurations, or the datasets used for training can be leaked.

8. Securing Machine Learning Algorithms, ENISA.

Threat Name	Threat Description
No Explainability	Some AI systems produce results, and even the developers need help explaining why these results are produced. This has several inherent risks and needs to be avoided.
No Transparency	A lack of communication about which data is processed and to what results can lead to uncomfortable feelings by the end user, mainly if, e.g., privacy data are processed.
No Validation and Verification	Outputs generated by the AI system need to be thoroughly validated and verified before being used for decision-making or disseminated to the public. This could involve fact-checking the information or consulting with subject matter experts.
Poisoning	If the attacker has access to training data and can alter them and introduce manipulations such as wrong labels so that the AI system, trained on poisoned data, carries out processing and predictions following the attacker's interests.
Prompt Injection	The output AI systems should be restricted using guardrails. Circumventing these guardrails can lead to using an AI system for malicious attacks.
Unfair Processing	This can happen whenever the AI algorithm does not give correct predictions—this can relate to credits not being granted or predictions not being accurate, leading to unwanted results.
Unlawful Processing	Any unlawful use of personal data, as well as processing that violates other laws or regulations, falls into this category.
Use of Vulnerable Code	If AI systems are used to support programming, the code provided must be checked thoroughly for exploitable code. This is particularly important before moving to production.

Appendix D: Vulnerabilities and Threat Mapping

	Data-related Threats			Model-related Threats			Component-related Threats		Operational Threats			Human-related Threats			System Integrity Threats								
Threats	Data Poisoning/Label Modification	Data or Model Disclosure	Data Interception	Input of Confidential, IP, and PII Data	Adversarial Attacks	Evasion	Bias	Model Theft or Disclosure	Hallucination (GenAI)	Direct Back-end Attack/Prompt Injection	Compromise of a Component	Failure or Malfunction of AI System	Supply Chain Vulnerabilities	Insecure API Interaction	Insufficient Logging	No validation and Verification	Unauthorized Access/Retrieval	Advanced Social Engineering Attacks	Human Error	Unfair/Unlawful Processing	Abuse	No Explainability	Use of Vulnerable Code
Vulnerabilities																							
1. Data Quality and Integrity Issues																							
Based Training Methods		●			●		●	●												●			
Human Error			●														●	●					
Inputs Crafted to Deceive AI Models into Making Incorrect Predictions		●			●				●														
Malicious Data Injected into Training Sets to Manipulate Outcomes	●				●				●														
Use of Unreliable Sources to Label Data	●				●				●														
Use of Unsafe Data or AI Models	●																			●			
Wrongly Selected Training Data					●		●		●			●											
2. Data Validation and Control																							
Insufficient Input Validation					●						●									●			
Lack of Control of Training Data	●						●					●											
Lack of Training Data Quality												●											
Lack of Training Data to Increase Robustness	●			●			●																
3. Access and Authorization																							
Compromised APIs Allowing Unauthorized Access or Data Manipulation			●			●								●			●						
Execution of Actions Without Appropriate Authorization																					●		
Inadequate Authentication and Authorization			●		●												●				●		
Insufficient Access Rights Allocation								●															

	Data-related Threats			Model-related Threats			Component-related Threats		Operational Threats			Human-related Threats			System Integrity Threats								
Threats Vulnerabilities	Data Poisoning/Label Modification	Data or Model Disclosure	Data Interception	Input of Confidential, IP, and PII Data	Adversarial Attacks	Evasion	Bias	Model Theft or Disclosure	Hallucination (GenAI)	Direct Back-end Attack/Prompt Injection	Compromise of a Component	Failure or Malfunction of AI System	Supply Chain Vulnerabilities	Insecure API Interaction	Insufficient Logging	No validation and Verification	Unauthorized Access/Retrieval	Advanced Social Engineering Attacks	Human Error	Unfair/Unlawful Processing	Abuse	No Explainability	Use of Vulnerable Code
Lack of Access Control						●		●		●													
Lack of Awareness of Social Engineering Attacks					●													●	●				
Lack of Internal Policies					●											●		●	●				
Poor Access Rights Management		●			●												●						
Unauthorized Entities Gaining Access to AI Systems or Data		●			●												●						
4. Design and Development																							
Exploiting Weaknesses in Third-party Components or Libraries Used by the AI System					●								●										
Implicit Bias in Evaluation Metrics					●		●																
Insufficient Supervision						●													●				
Lack of Comprehensive Logging to Detect and Respond to Security Incidents					●										●								
Lack of Awareness				●												●			●				●
Lack of Documentation															●				●			●	
Lack of Integrity Checks and Validation Procedures																●							●
Lack of Monitoring of the Use of AI Systems					●			●		●								●					
Lack of Privacy by Design					●						●									●			
Lack of Secure Software Development Lifecycle					●						●												●
Lack of Security Process to Maintain Good Security Levels (Secure-by-Design)	●									●													

	Data-related Threats				Model-related Threats			Component-related Threats	Operational Threats			Human-related Threats			System Integrity Threats								
Threats \ Vulnerabilities	Data Poisoning/Label Modification	Data or Model Disclosure	Data Interception	Input of Confidential, IP, and PII Data	Adversarial Attacks	Evasion	Bias	Model Theft or Disclosure	Hallucination (GenAI)	Direct Back-end Attack/Prompt Injection	Compromise of a Component	Failure or Malfunction of AI System	Supply Chain Vulnerabilities	Insecure API Interaction	Insufficient Logging	No validation and Verification	Unauthorized Access/Retrieval	Advanced Social Engineering Attacks	Human Error	Unfair/Unlawful Processing	Abuse	No Explainability	Use of Vulnerable Code
Lack of Sufficient Design Specification											●									●		●	
Lack of Traceability of Actions																						●	
Lack of Training																			●				
Weakness in the Models Used					●	●																	
Wrong or Insufficient Product Specification																				●		●	
5. Communication and Information Disclosure																							
Insecure Communication Channels		●																					
Existence of Unidentified Disclosure Scenarios		●																					
Lack of Awareness of Legal Requirements				●														●	●				
Too Much Information About the Model Given in Its Outputs						●																	
Unnecessary Provision of Information About AI Models Used								●															
Unprotected Sensitive Data on Test Environments		●			●												●						
6. Protection Mechanisms																							
Lack of Capacity Planning												●	●										
Lack of Suitable Cloud Arrangements		●	●									●		●			●						
Lack of Business Continuity Planning		●										●	●				●						
Weak Access Protection Mechanisms for ML Model Components		●			●																		
Use of Vulnerable Components					●						●									●			

حكومة دبي
GOVERNMENT OF DUBAI



مركز دبي للأمن الإلكتروني
DUBAI ELECTRONIC SECURITY CENTER



Dubai Electronic Security Center

desc.gov.ae